

Authentication & Authorization Guide

Enhancing Security in Messaging Applications

Spinnaker Analytics

26 June 2026

Table of Contents

1. Introduction
2. Authentication Architecture
3. Password-Based Authentication
4. Multi-Factor Authentication (MFA)
5. Biometric Authentication
6. Role-Based Access Control (RBAC)
7. Session Management
8. Account Recovery & Credential Reset
9. Authentication Security Testing
10. Security Considerations
11. Conclusion

1. Introduction

1.1 Purpose

- This document defines the authentication and authorization mechanisms used to secure access to the messaging application.
- The objective is to ensure that only authorized users can access application resources while protecting user identities, credentials, and session information.

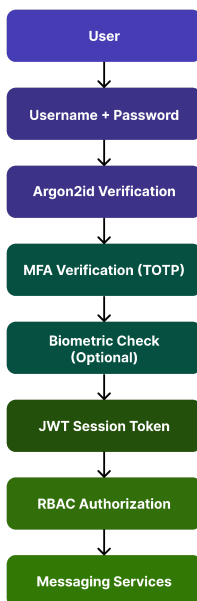
1.2 Objectives

- Strong user authentication
- Multi-factor verification
- Biometric login support
- Fine-grained authorization
- Secure session management
- Account recovery controls
- Protection against credential attacks

2. Authentication Architecture

- Authentication occurs through multiple security layers:
 - Password Verification
 - MFA Verification
 - Biometric Verification (Optional)
 - Session Token Issuance
 - RBAC Authorization

Figure 7 – Authentication Architecture



2.1 Authentication Components

Component	Technology
Password Hashing	Argon2id
MFA	TOTP
Biometrics	Android BiometricPrompt
Session Token	JWT
Authorization	RBAC
Transport Security	TLS 1.3

3. Password-Based Authentication

3.1 Password Requirements

Requirement	Value
Minimum Length	12 Characters
Uppercase	Required
Lowercase	Required
Numeric	Required
Special Character	Required

3.2 Account Lockout Policy

Setting	Value
Failed Attempts	5
Lockout Duration	15 Minutes
Progressive Delays	Enabled
Logging	Enabled

3.3 Password Hashing

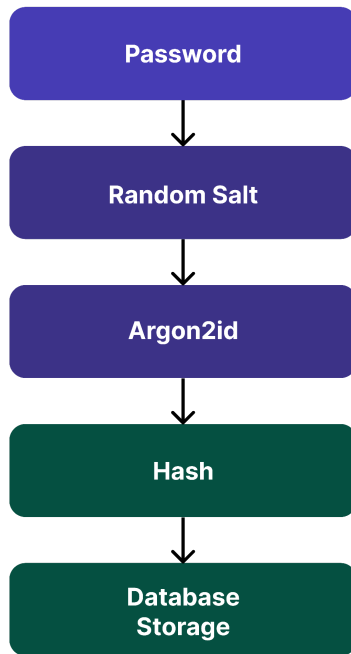
Algorithm: Argon2id

Configuration:

Parameter	Value
Memory Cost	64 MB
Iterations	3
Parallelism	4
Salt Length	16 Bytes

3.4 Password Storage Workflow

Figure 8 – Password Processing



3.5 Security Benefits

- Protection against rainbow tables
- Resistance to brute force attacks
- Unique salted hashes

4. Multi-Factor Authentication (MFA)

4.1 MFA Architecture

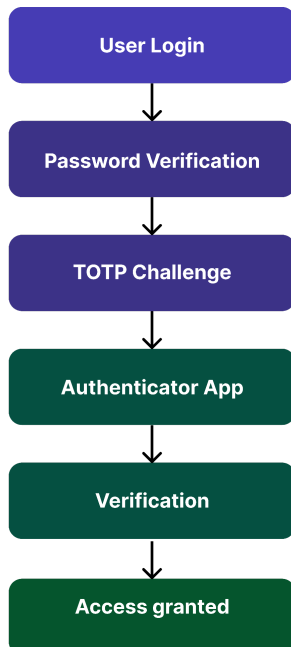
- The application uses:
 - Time-Based One-Time Passwords (TOTP)
- Standard:
 - RFC 6238

4.2 Supported Authenticators

Authenticator	Supported
Google Authenticator	Yes
Microsoft Authenticator	Yes
Aegis Authenticator	Yes
Authy	Yes

4.3 MFA Workflow

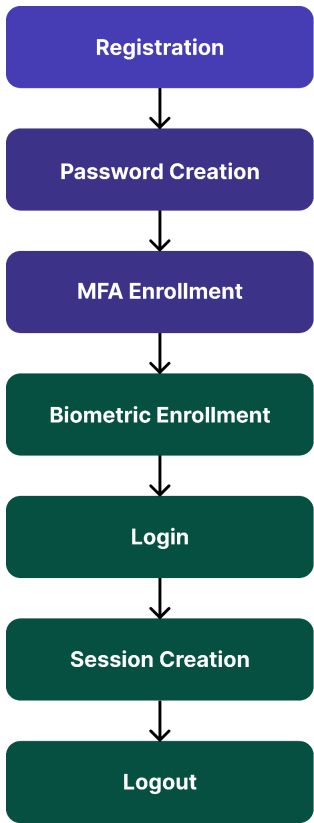
Figure 9 : MFA Workflow



4.4 TOTP Configuration

Parameter	Value
Algorithm	SHA-256
Code Length	6 Digits
Validity	30 Seconds

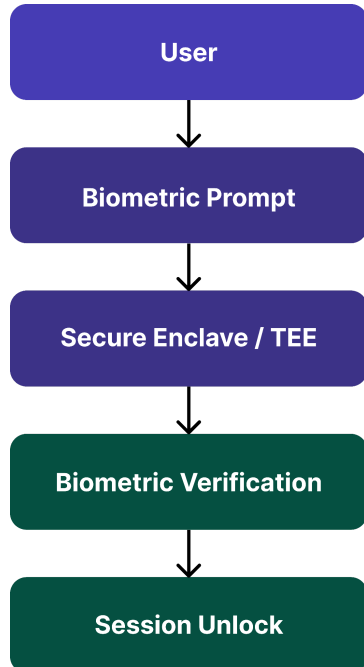
4.5 Authentication Lifecycle Diagram



5. Biometric Authentication

- Biometric authentication provides convenience while maintaining strong security.
 - Supported Biometrics
 - Android
 - Fingerprint
 - Face Recognition
 - iOS
 - Face ID
 - Touch ID

Figure 10 – Biometric Authentication Flow



- **Security Requirements**
 - Biometrics never leave device
 - Templates stored in hardware security module
 - Failed attempts trigger fallback authentication

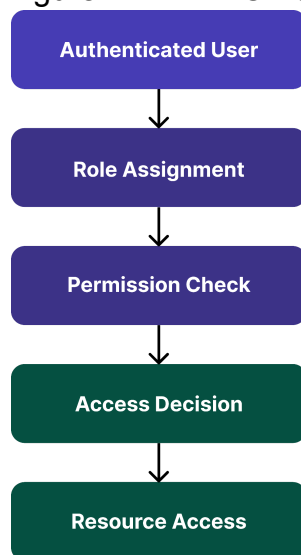
6. Role-Based Access Control (RBAC)

6.1 Authorization is enforced through RBAC.

- Role Matrix:

Permission	User	Moderator	Admin
Send Messages	Yes	Yes	Yes
Receive Messages	Yes	Yes	Yes
File Transfers	Yes	Yes	Yes
Manage Users	No	Yes	Yes
System Configuration	No	No	Yes
Security Logs	No	No	Yes

Figure 11 – RBAC Authorization Flow



6.2 Principle of Least Privilege

- Users receive only permissions required to perform their functions.

7. Session Management

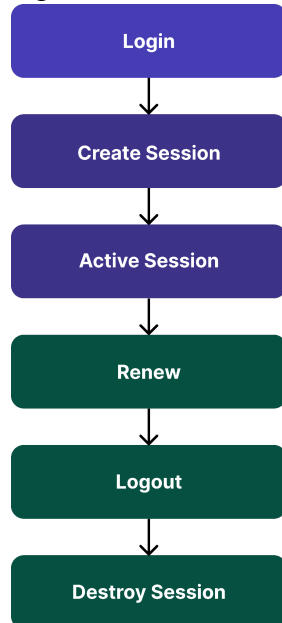
7.1 Session Creation

- After successful authentication:
 - JWT Token Issued
 - Session ID Generated
 - Secure Cookie Created

7.2 Session Controls

Control	Value
Idle Timeout	15 Minutes
Maximum Session Duration	24 Hours
Token Rotation	Every Login
Secure Cookie	Enabled
HttpOnly	Enabled

Figure 12 – Session Lifecycle



7.3 Session Token Security Table

Token Control	Configuration
Signing Algorithm	RS256
Expiry	15 Minutes
Refresh Token	Enabled
Rotation	Every Login
Revocation	Supported

7.4 Session Security

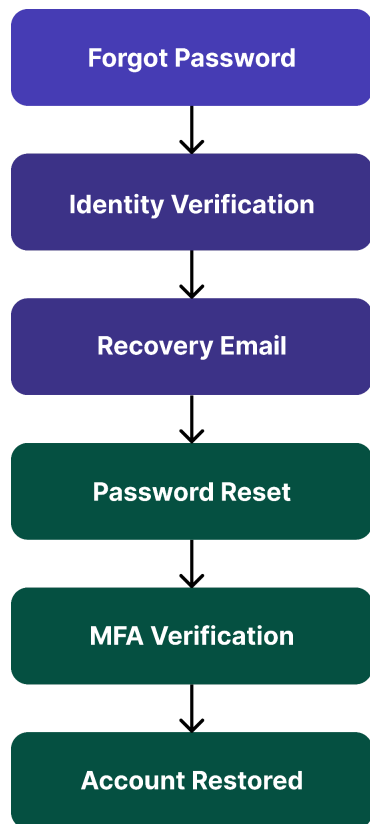
- JWT signing
- Secure cookie flags
- Session revocation
- Device tracking

8. Account Recovery & Credential Reset

8.1 Recovery Methods

- **Email Verification**
 - Recovery link sent to registered email.
- **Backup Recovery Codes**
 - Generated during MFA enrollment.

Figure 13 – Account Recovery Process



8.2 Security Controls

- Recovery token expiry: 15 minutes
- Single-use recovery links
- Recovery activity logging

9. Authentication Security Testing

9.1 Testing Environment

Tool	Purpose
Burp Suite	Authentication Testing

MobSF	Mobile Security
OWASP ZAP	Session Testing
Frida	Runtime Validation

9.2 Test Cases

Test ID	Test Scenario	Expected Result
AUTH-01	Invalid Password	Access Denied
AUTH-02	MFA Failure	Login Blocked
AUTH-03	Biometric Failure	Fallback Prompt
AUTH-04	Session Expiration	Reauthentication Required
AUTH-05	RBAC Violation	Access Denied
AUTH-06	Password Reset	Verified Recovery

9.3 Validation Objectives

- Verify:
 - Password hashing active
 - MFA enforced
 - Biometric authentication functional

- RBAC working correctly
- Session expiration enforced
- Recovery procedures secure

10. Security Considerations

10.1 Threats & Mitigations

Threat	Mitigation
Credential Stuffing	MFA
Brute Force Attack	Rate Limiting
Session Hijacking	Secure Cookies
Session Fixation	Session Rotation
JWT Theft	Secure Storage
MFA Fatigue	TOTP Only
Privilege Escalation	RBAC
Account Takeover	MFA + Biometrics
Replay Attack	Nonces + TLS

10.2 Security Standards Alignment

Standard	Purpose
NIST SP 800-63B	Authentication
OWASP ASVS	Authentication Controls
OWASP MASVS	Mobile Authentication
RFC 6238	TOTP
RFC 7519	JWT

11. Conclusion

- This Authentication & Authorization Guide defines a layered identity security architecture based on:
 - Argon2id password hashing
 - TOTP multi-factor authentication
 - Biometric authentication
 - Role-Based Access Control
 - Secure session management
 - Account recovery protections
- The proposed controls significantly reduce the risk of unauthorized access, credential compromise, account takeover, and privilege escalation while maintaining a secure and user-friendly authentication experience.